

MODULE 43 · EXAM STRATEGY - ALL DOMAINS

Practice exam 4 of 4

20 questions, weighted toward governance. The last paper – treat this one as a dress rehearsal.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

A company allows customers to upload documents to an S3 bucket, which downstream services then process. Security requires that uploaded objects are scanned for malware before any downstream service reads them.

The team wants a managed capability rather than building a scanning pipeline.

What should the company enable?

- ☐ A GuardDuty Malware Protection for S3 on the bucket
- ☐ B Amazon Inspector, configured to scan the bucket's objects
- ☐ C Macie automated sensitive data discovery on the bucket
- ☐ D GuardDuty Runtime Monitoring on the processing instances

◆ PAUSE AND DECIDE

What should the company enable?

- A

GuardDuty Malware Protection for S3
Correct. It scans newly uploaded objects for malware and tags the result, so downstream services can act on the verdict before reading.
- B

Inspector on the objects
Inspector finds software vulnerabilities in workloads, images and code. It does not scan arbitrary uploaded files for malware.
- C

Macie discovery
Macie classifies sensitive data. It answers what is in the file, not whether the file is hostile.
- D

Runtime Monitoring on the instances
Detects malicious behaviour after something executes. The requirement says before any downstream service reads the object.

DOMAIN 1

Malware in an object is GuardDuty. Vulnerabilities in software is Inspector. Sensitive data in a file is Macie.

A company retains 400 TB of verbose application logs in CloudWatch Logs for compliance. The logs are read only during investigations, roughly four times a year. Cost has become significant.

The team still needs to run Logs Insights queries against them when an investigation happens.

What should the team do?

- ☐ A Reduce the retention period to 30 days and accept the compliance risk
- ☐ B Export the log groups to S3 Glacier Deep Archive and delete them from CloudWatch Logs
- ☐ C Move the log groups to the Infrequent Access log class, which supports Logs Insights at lower ingestion cost
- ☐ D Enable a subscription filter to Firehose and store the logs in S3 instead

◆ PAUSE AND DECIDE

What should the team do?

- A

 Cut retention to 30 days
Solves cost by breaking the stated compliance requirement. Never the answer when the requirement is given.
- B

 Export to Deep Archive and delete
Cheapest storage, and retrieval takes hours and Logs Insights cannot query it. The requirement says Insights must still work.
- C

 Infrequent Access log class
Correct. IA offers substantially lower ingestion cost and still supports Logs Insights - built for exactly this read-rarely, keep-long pattern.
- D

 Subscription filter to S3
A reasonable archive pattern that loses Logs Insights, and you pay standard ingestion into CloudWatch Logs before the filter fires anyway.

DOMAIN 1

IA trades away some capabilities for cost – but Logs Insights is not one of them. That is what makes it fit here.

A company connects 60 VPCs through a Transit Gateway. During an investigation, the team could see traffic entering and leaving each VPC, but could not determine which VPC attachment a flow traversed, or reconstruct the path between two VPCs.

VPC Flow Logs are enabled on every VPC.

What should the company enable?

- ☐ A VPC Flow Logs in a custom format including the pkt-srcaddr field
- ☐ B Network Access Analyzer scopes between each pair of VPCs
- ☐ C Route 53 Resolver query logging on every VPC
- ☐ D Transit Gateway Flow Logs

◆ PAUSE AND DECIDE

What should the company enable?

A Custom format with pkt-srcaddr

Useful for seeing the original source behind a NAT or gateway. It still gives you no attachment-level view of the Transit Gateway itself.

C Resolver query logging

Records DNS queries. It says nothing about which attachment a flow traversed.

B Network Access Analyzer scopes

Proves whether a path can exist. The team is reconstructing traffic that did happen, which is a different question.

D Transit Gateway Flow Logs

Correct. They capture flows at the Transit Gateway with attachment-level detail, which is exactly the east-west visibility VPC Flow Logs cannot give.

DOMAIN 1

VPC Flow Logs see traffic at the VPC edge. Transit Gateway Flow Logs see it at the hub, with the attachment named.

A company is designing a dedicated forensics account. An architect proposes that the forensics account trust a role in the production account, so responders can pivot into production quickly during an incident.

A reviewer objects to the direction of trust.

What is the correct design?

- ☐ A The architect's design; responders need fast access to production
- ☐ B Production trusts a forensics role, with no trust path from forensics back into production
- ☐ C Both accounts trust each other, to allow evidence to move in either direction
- ☐ D Neither account trusts the other; move evidence through a shared S3 bucket with public access

◆ PAUSE AND DECIDE

What is the correct design?

- A

 Forensics trusts production
Inverts the risk. If production is compromised – which is the assumption during an incident – the attacker inherits a path into the forensics account.
- C

 Mutual trust
Includes the direction that is wrong. Convenience in both directions means compromise in both directions.
- B

 Production trusts forensics; no path back
Correct. The clean account reaches into the dirty one, never the reverse, so a compromised production account cannot reach the evidence.
- D

 A public bucket
Publishing evidence to the internet to avoid configuring a role. Every part of this is worse than the problem.

DOMAIN 2

Trust flows from clean to dirty, never back. During an incident you assume production is compromised.

A company has documented a four-hour recovery time objective and a fifteen-minute recovery point objective for a multi-Region application. Leadership wants an assessment of whether the current architecture can actually meet those targets, and where it falls short. The company already runs game days using AWS Fault Injection Service.

What should the company add?

- ☐ A More FIS experiments, covering additional failure modes
- ☐ B AWS Backup restore testing on the application's data stores
- ☐ C CloudWatch synthetic canaries measuring recovery time during game days
- ☐ D AWS Resilience Hub, assessing the application against its RTO and RPO

◆ PAUSE AND DECIDE

What should the company add?

A More FIS experiments

FIS proves what happens when something breaks. It does not assess an architecture against a stated RTO and RPO or tell you where it falls short.

C Synthetic canaries during game days

Measures what happened during one exercise. The requirement is an assessment of the architecture, not a stopwatch on a single test.

B Backup restore testing

Genuinely valuable and narrower – it validates that backups restore, not whether the whole architecture meets its objectives.

D Resilience Hub against RTO and RPO

Correct. Resilience Hub assesses an application against its stated recovery objectives and reports where the architecture cannot meet them.

DOMAIN 2

FIS answers 'does it survive'. Resilience Hub answers 'will it meet the objective, and where does it fall short'.

Auditors require a record of every command an engineer runs on production EC2 instances, attributable to a named individual, with no inbound ports open on the instances and no SSH keys distributed.

The instances are in private subnets.

What should the company use?

- ☐ A Systems Manager Session Manager with session logging to CloudWatch Logs or S3
- ☐ B EC2 Instance Connect, with CloudTrail recording the connections
- ☐ C A hardened bastion host with SSH key pairs issued per engineer
- ☐ D EC2 Serial Console access, restricted by IAM policy

◆ PAUSE AND DECIDE

What should the company use?

- A

 Session Manager with session logging
Correct. No inbound ports, no keys, IAM-attributed identity, and session logging records the commands themselves rather than just the connection.
- B

 EC2 Instance Connect
The sharpest distractor. Instance Connect removes stored keys and CloudTrail records that a connection happened – but not what was typed during it.
- C

 A bastion with per-engineer keys
Requires an inbound port and distributed keys, both of which the requirement forbids, and command capture would have to be built separately.
- D

 Serial Console
An emergency recovery path for boot-level problems, not a routine access mechanism, and it does not give per-command logging.

DOMAIN 3

Instance Connect logs the connection. Session Manager logs the content. The requirement names commands, not sessions.

A company must apply the same baseline AWS WAF rule group to every Application Load Balancer and CloudFront distribution across 80 accounts, including resources created next month, and must be alerted when a resource is out of compliance.

Some teams also protect Route 53 hosted zones and use AWS Global Accelerator.

What should the company use, and what will it not cover?

- ☐ A StackSet deploying a web ACL to every account; it covers all resource types
- ☐ Firewall Manager WAF policies; they cover Route 53 and Global Accelerator too
- ☐ Firewall Manager WAF policies, which do not support Route 53 or Global Accelerator
- ☐ Shield Advanced, which applies WAF rules organisation-wide

◆ PAUSE AND DECIDE

What should the company use, and what will it not cover?

- A

A StackSet deploying web ACLs

Deploys the ACL and does not associate it with resources created later, nor report compliance. That automatic association is what Firewall Manager adds.
- B

Firewall Manager, covering Route 53 and Global Accelerator

Right service, wrong coverage claim. This is the trap - it is a documented exception that catches people out.
- C

Firewall Manager, which does not support Route 53 or Global Accelerator

Correct. FMS applies policies org-wide with automatic association and compliance reporting - and those two resource types are documented exceptions.
- D

Shield Advanced

Provides DDoS protection and response support. It is not the mechanism for distributing WAF rule groups across accounts.

DOMAIN 3

Options B and C name the same service. The difference is whether you know the documented exception.

A company must produce hardened, patched AMIs monthly, apply a CIS benchmark, scan each image for vulnerabilities before release, and distribute approved images to 30 accounts.

Teams must not be able to launch instances from unapproved images.

Which combination should the company use?

- ☐ A A manual golden AMI build, shared via snapshot permissions, with a Config rule detecting unapproved AMIs
- ☐ B EC2 Image Builder pipelines with a CIS hardening component and an Inspector scan, plus the Allowed AMIs setting enforced by declarative policy
- ☐ C Patch Manager patch baselines applied to running instances, with AMIs created afterwards
- ☐ D A third-party AMI from AWS Marketplace, subscribed in each account

◆ PAUSE AND DECIDE

Which combination should the company use?

A Manual build plus a Config rule

Detective on the last requirement - it finds unapproved AMIs after instances launch from them. Manual builds also drift month to month.

C Patch Manager then capture AMIs

Patches running instances rather than producing a repeatable image pipeline. It also skips hardening, scanning and distribution.

B Image Builder with CIS component and Inspector, plus Allowed AMIs

Correct. Image Builder covers build, harden, scan and distribute; Allowed AMIs prevents launching anything else, enforced org-wide as configuration.

D A Marketplace AMI

Outsources the image without meeting the CIS benchmark, the scan-before-release step, or the restriction on unapproved images.

DOMAIN 3

Four requirements plus a prevention clause. Image Builder covers the pipeline; Allowed AMIs covers the 'must not launch' part.

An analytics account must read objects from a bucket in a data account. The objects are encrypted with a customer managed KMS key in the data account. The bucket policy allows the analytics role, and the analytics role's identity policy allows `s3:GetObject` and `kms:Decrypt` on the key ARN.

Requests fail with `AccessDenied`. There are no SCPs or RCPs.

What is missing?

- ☐ A The analytics role needs a permissions boundary permitting `kms:Decrypt`
- ☐ B The bucket must use SSE-S3 for cross-account access to work
- ☐ C The KMS key policy in the data account must allow the analytics role
- ☐ D The analytics account must create a replica of the key

◆ PAUSE AND DECIDE

What is missing?

- A

 A permissions boundary permitting Decrypt
A boundary caps permissions; it never grants them. Adding one cannot supply access the key policy has not given.
- C

 The KMS key policy must allow the analytics role
Correct. The key policy is the root of trust. Cross-account access needs both accounts to allow, and the key policy is the data account's half.
- B

 Use SSE-S3 instead
Would remove the KMS step and the control with it. It solves the symptom by abandoning the customer managed key.
- D

 Create a key replica
Replicas are for multi-Region keys and are not a cross-account mechanism. Both accounts are in the same Region here.

DOMAIN 4

Three policies were checked and the fourth was not. The key policy is never optional.

A company adds a policy requiring MFA for sensitive actions, using a Deny with a condition on `aws:MultiFactorAuthPresent` equal to `false`. Console users with MFA are unaffected, as intended.

Automation using long-term IAM user access keys, which cannot present MFA, continues to perform the sensitive actions successfully.

Why, and how should it be fixed?

- ☐ A Access keys always satisfy the MFA condition; move the automation to a role
- ☐ B The condition must be applied in an Allow rather than a Deny
- ☐ C MFA cannot be enforced for programmatic access at all
- ☐ D `aws:MultiFactorAuthPresent` is absent for long-term keys, so `Bool false` never matches; use `BoolIfExists`

◆ PAUSE AND DECIDE

Why, and how should it be fixed?

A Access keys satisfy the condition

They do not satisfy it – the key is simply not present on the request. Moving to a role is good advice for a different reason.

C MFA cannot be enforced programmatically

Too strong. BoolIfExists closes exactly this gap, and temporary credentials from an MFA-authenticated session do carry the key.

B Use an Allow instead

Changes nothing about whether the condition key exists on the request. An absent key fails to match in an Allow too.

D The key is absent; use BoolIfExists

Correct. aws:MultiFactorAuthPresent only exists on requests made with temporary credentials. Bool false cannot match an absent key; BoolIfExists treats absence as false.

DOMAIN 4

A condition key that is absent never matches – and never errors. This is the single most common MFA policy bug.

A company with 5,000 IAM roles across 120 accounts must identify roles nobody has used in the last 90 days, and permissions granted to active roles that have never been exercised, so it can remove both.

The company wants findings rather than a manual review of policies.

What should the company use?

- ☐ A The IAM policy simulator, run against every role
- ☐ B IAM Access Analyzer unused access analyzers
- ☐ C IAM Access Analyzer external access analyzers
- ☐ D CloudTrail Lake queries counting invocations per role

◆ PAUSE AND DECIDE

What should the company use?

- A

The policy simulator per role
Simulates whether a hypothetical request would be allowed. It says nothing about whether anyone actually used the permission.
- C

External access analyzers
Report resource policies granting access outside the zone of trust. That is a different question entirely.
- B

Unused access analyzers
Correct. They surface unused roles, unused access keys and console passwords, and unused service and action-level permissions - both halves of the requirement.
- D

CloudTrail Lake queries
Could establish which roles were used, with real query effort, and it would not identify unexercised permissions within an active role.

DOMAIN 4

Two requirements - unused roles and unused permissions within used roles - and one analyzer type covers both.

A company has 40 AWS accounts and 600 staff who need console and CLI access. Today each account has its own IAM users. The company wants central management, access assigned by group, temporary credentials only, and no per-account user administration. It already operates an external identity provider.

What should the company implement?

- ☐ A IAM Identity Center with the external IdP as identity source, SCIM provisioning, and permission sets assigned to groups
- ☐ B A SAML identity provider in each of the 40 accounts, with roles per job function
- ☐ C One shared account holding all IAM users, with cross-account roles into the other 39
- ☐ D Cognito user pools federated to the identity provider, with an identity pool per account

◆ PAUSE AND DECIDE

What should the company implement?

- A

 Identity Center with external IdP, SCIM and group-assigned permission sets
Correct. Central management, group assignment, temporary credentials, and SCIM keeps membership in step with no per-account administration.
- B

 A SAML provider in each account
Works, and it is 40 provider objects and 40 sets of roles to maintain. Valid architecture, but it is per-account administration by another name.
- C

 One shared IAM user account
Keeps 600 long-lived credentials, just in one place. It centralises the problem rather than removing it.
- D

 Cognito per account
Cognito serves application end users. Staff console and CLI access is Identity Center territory.

DOMAIN 4

'No per-account user administration' is the clause. Option B is a real architecture that fails exactly that requirement.

A media pipeline creates a KMS grant for a processing role and immediately calls `GenerateDataKey` with that role. About one job in six fails with `AccessDenied`. Retrying a few minutes later always succeeds.

The grant is created correctly every time, with the right grantee and operations.

What is happening, and what is the fix?

- ☐ A The 50,000 grant limit per key is being reached; delete old grants
- ☐ B `GenerateDataKey` is not a valid grant operation; use `Encrypt`
- ☐ C The processing role also needs `kms:CreateGrant`
- ☐ D Grants are eventually consistent; pass the `GrantToken` returned by `CreateGrant`

◆ PAUSE AND DECIDE

What is happening, and what is the fix?

- A

 Hitting the 50,000 grant limit
That produces a consistent failure at a threshold, and it would not resolve itself on a retry minutes later.
- B

 GenerateDataKey is not valid
It is valid for a symmetric encryption key. Sign and GenerateMac would not be – and it would fail every time, not one in six.
- C

 The role needs kms:CreateGrant
CreateGrant is what the pipeline already did successfully. The processing role is the grantee, not the creator.
- D

 Eventual consistency; pass the GrantToken
Correct. Grant creation takes up to about five minutes to propagate. The token from CreateGrant gives a strongly consistent check immediately.

DOMAIN 5

Intermittent failure that a retry fixes is eventual consistency. A permissions problem fails every time.

An airline replicates data continuously from eu-west-1 to us-east-1. During a failover exercise, applications in us-east-1 could not decrypt the replicated data, because the KMS key lives in eu-west-1 and cross-Region KMS calls failed.

us-east-1 must be able to decrypt with no dependency on eu-west-1, and no data may be re-encrypted during migration.

What should the airline implement?

- ☐ A Enable automatic rotation, which replicates the key material
- ☐ B Create a us-east-1 key and re-encrypt all replicated data
- ☐ C Create a multi-Region key, replicate it to us-east-1, and migrate data to it going forward
- ☐ D Add a us-east-1 role to the eu-west-1 key policy and call KMS cross-Region

◆ PAUSE AND DECIDE

What should the airline implement?

- A

 Rotation replicates the material
Rotation changes material within one key. It does not create a key in another Region, and a single-Region key cannot become multi-Region.
- B

 New key and re-encrypt everything
Works, and the requirement says no data may be re-encrypted. It is also a large, risky operation over live data.
- C

 Multi-Region key, replicated, data migrated forward
Correct. Replicas share key material and can decrypt each other's ciphertext with no cross-Region call – exactly what a failover needs.
- D

 Cross-Region calls with a policy change
This is the architecture that just failed. A failover is precisely the case where eu-west-1 is unreachable.

DOMAIN 5

The honest caveat: you cannot convert the existing key, so old ciphertext still needs it. 'Going forward' is doing real work in option C.

A shared services account must give a partner account read access to a database credential held in Secrets Manager. A resource policy is added to the secret allowing the partner's role, and the partner's identity policy allows `secretsmanager:GetSecretValue`. The partner still receives `AccessDenied`. The secret uses the default AWS managed key.

What is required?

- ☐ A Re-encrypt the secret under a customer managed key and grant the partner `kms:Decrypt` on it
- ☐ B Grant the partner account `kms:Decrypt` on the AWS managed key
- ☐ C Replicate the secret into the partner's account
- ☐ D Enable automatic rotation, which regenerates the secret with shareable encryption

◆ PAUSE AND DECIDE

What is required?

- A

 Re-encrypt under a CMK and grant kms:Decrypt
Correct. A customer managed key has a policy you control, so the partner can be granted use of it. That is the only way to share.
- B

 Grant Decrypt on the AWS managed key
You cannot modify the key policy of an AWS managed key, so nobody can be granted use of it. This is exactly why the share fails.
- C

 Replicate the secret
Replica secrets are for multi-Region availability within your own organisation, not a cross-account sharing mechanism.
- D

 Rotation regenerates it shareably
Rotation changes the value, not the encrypting key. The sharing block is unchanged.

DOMAIN 5

Nothing encrypted with an AWS managed key can be shared. Same rule as EBS snapshots, in a different service.

An organisation wants to enforce that EBS snapshots can never be shared publicly, across all accounts. It is concerned that a deny-based policy will be outgrown when AWS adds new sharing mechanisms, as has happened twice before.

Before enforcing, the security team wants to see which accounts are currently non-compliant.

What should the organisation use?

- ☐ A An SCP with NotAction, denying everything except permitted EC2 actions
- ☐ B A declarative policy for EBS, using account status reports to see the current state before enforcing
- ☐ C A Config rule with automatic remediation across the organisation
- ☐ D A proactive Control Tower control on snapshot creation

◆ PAUSE AND DECIDE

What should the organisation use?

A An SCP with NotAction

Would cover new actions and denies everything else in EC2 too. An enormous blast radius, and it offers no view of current state.

C Config rule with remediation

Detective and corrective. The snapshot is public during the window before remediation runs.

B A declarative policy with account status reports

Correct. Declarative policies enforce configuration at the service level and survive new APIs – and account status reports show the gap before you enforce.

D A proactive control

CloudFormation hooks only see CloudFormation-provisioned resources. Sharing a snapshot is an API call, not a provisioning event.

DOMAIN 6

Two requirements: survive new APIs, and see the gap first. Account status reports are the second half people forget.

An organisation applies an SCP at the root denying s3:DeleteBucket. An audit finds buckets being deleted in one account. The SCP is attached correctly and is syntactically valid, and all deletions occurred in the same account.

That account also hosts a legacy reporting workload.

What is happening, and what should be done?

- ☐ A SCP changes take up to 24 hours to apply; wait and re-audit
- ☐ B The SCP must also be attached to each OU to take effect
- ☐ C The account is the management account, which SCPs do not restrict; move the workload to a member account
- ☐ D The account has an SCP exemption for S3 actions only

◆ PAUSE AND DECIDE

What is happening, and what should be done?

A Wait 24 hours

SCP changes apply quickly, and the deletions have been happening long enough for an audit to find them. Delay does not explain a consistent exemption.

C It is the management account; move the workload

Correct. SCPs have no effect there, deliberately, so that a bad SCP cannot lock the organisation out. The design rule is to run no workloads in it.

B Attach to each OU

A root-attached SCP already applies to every OU and account beneath it. Attaching per OU is redundant – and would not reach the management account either.

D An S3-only exemption

Half a real fact. The management account is exempt from SCPs entirely, not from one service's actions.

DOMAIN 6

Every non-compliant action in one account, with a valid root-attached SCP. That is the management account exemption.

During an ISO 27001 audit, the auditor asks the company to evidence that the physical facilities hosting its workloads have appropriate environmental and access controls, and requests supporting documentation.

The company cannot inspect AWS data centres.

Where should the company obtain this?

- ☐ A A Config conformance pack aligned to ISO 27001
- ☐ B Security Hub CSPM findings exported for the audit period
- ☐ C An AWS support case requesting a facilities attestation
- ☐ D AWS Artifact, which provides AWS's ISO 27001 certification

◆ PAUSE AND DECIDE

Where should the company obtain this?

- A

An ISO 27001 conformance pack
Config rules evaluate AWS resource configuration. No Config rule can inspect a door, a generator or a cooling system.
- B

Security Hub CSPM findings
Evaluates your resources against a standard. It says nothing about AWS's facilities.
- C

A support case
Unnecessary – the documents are published for self-service download, which is the entire purpose of Artifact.
- D

AWS Artifact's ISO 27001 certification
Correct. Physical and environmental security is AWS's half of the shared responsibility model, and Artifact is how AWS evidences its own controls.

DOMAIN 6

Artifact is evidence about AWS. Everything else in this list is evidence about you.

A CISO wants a structured, repeatable assessment of one production workload's security posture, producing risk-rated findings and an improvement plan that engineering can prioritise. She explicitly does not want a compliance score against a named standard. The organisation already runs Security Hub CSPM with AWS Foundational Security Best Practices.

What should be used?

- ☐ A A Well-Architected Tool review of that workload against the security pillar
- ☐ B Add the NIST 800-53 standard in Security Hub CSPM
- ☐ C A Config conformance pack scoped to the workload's resources
- ☐ D Trusted Advisor security checks exported for engineering

◆ PAUSE AND DECIDE

What should be used?

- A

 A Well-Architected review against the security pillar
Correct. Workload-scoped, structured, repeatable, risk-rated findings and an improvement plan – and it surfaces Trusted Advisor checks by pillar too.
- B

 Add NIST 800-53
More compliance scoring against a named standard, which is explicitly what she does not want. It also evaluates accounts, not a workload.
- C

 A conformance pack for the workload
Config rules evaluate configuration continuously and produce compliance status, not a prioritised improvement plan.
- D

 Trusted Advisor checks
Shallow and account-scoped. It flags an open security group without judging whether that is wrong for this workload.

DOMAIN 6

Well-Architected reviews a workload. Security Hub CSPM scores an account. The requirement names the unit.

A company applies an Organizations tag policy requiring an Owner tag with values from an approved list. Six months later, 40% of resources still carry no Owner tag at all, and the tag policy reports no non-compliance for them.

Resources that do carry an Owner tag all use approved values.

Why, and what should be added?

- ☐ A The tag policy is in report-only mode; switch it to enforcement
- ☐ B Tag policies govern values but cannot require a tag; add an SCP denying creation when `aws:RequestTag/Owner` is Null
- ☐ C The untagged resources are in Regions outside the policy's scope
- ☐ D Tag policies evaluate only at creation; re-apply the policy to assess existing resources

◆ PAUSE AND DECIDE

Why, and what should be added?

A Switch to enforcement mode

Enforcement stops a non-compliant value being applied on supported resource types. A resource with no tag applies no value, so there is nothing to enforce against.

C Regions outside scope

Would produce no findings for those resources - and the company can see them, so they are within reporting scope. The gap is what a tag policy evaluates.

B Tag policies cannot require a tag; add an SCP with Null

Correct. The tag policy governs values; the SCP requires presence. Neither alone gives you 'tagged, and tagged correctly'.

D Re-apply to assess existing resources

Tag policies do report on existing resources. The absence of findings is the clue: an untagged resource is invisible to the policy, not non-compliant.

DOMAIN 6

'The tag policy reports no non-compliance for them' is the tell. Silence means the policy has nothing to evaluate.

Scoring practice exam 4, and where you are

- ◆ **Answer key:** A C D B D A C B C D B A D C A B C D A B.
- ◆ **Domains:** Q1-3 detection, Q4-5 IR, Q6-8 infrastructure, Q9-12 identity, Q13-15 data protection, Q16-20 governance.
- ◆ **Across all four papers: 80 questions**, weighted to the real distribution. No question appears twice.
- ◆ **Q7 is worth revisiting** – options B and C name the same service and differ on one documented exception.
- ◆ **Consistently 16+ across all four, unpaused, means you are ready.**

ON THE EXAM

That is the last practice exam. Sit them again in a week without looking at the answers – the second attempt is the one that tells you something.